40. Security Groups vs NACLs vs Host Firewalls

40. Security Groups vs NACLs vs Host Firewalls

Phase: Phase 8 — Firewalls, NAT, and policy
Estimated time: 1–2 days
Slug: `40-security-groups`

Learning objectives

- Contrast SG/NACL/host firewall layers
- Write least-privilege allowlists
- Debug timeouts vs resets
- Trace which layer drops

Prerequisites

Complete prior lessons. Prefer a Linux VM for `ip`/`ss`/`nft` examples; macOS works for many `curl`/`dig` drills.

Timeouts often mean **drop** (SG/NACL/firewall). Immediate RST may mean closed port on host.

```
# Client evidence
curl -v --connect-timeout 3 https://target:443 || true
nc -vz -w 3 target 443

# On host
ss -tulpn | grep 443
sudo nft list ruleset | head
```

Layered controls: cloud SG + host nft/ufw + app auth.

Common mistakes

- 0.0.0.0/0 on SSH in prod
- Only SGs, no host hardening
- Changing three layers at once

Exercises

Work in `exercises/40-security-groups/`:

```
./test.sh
```

- **A:** make tests pass
- **B:** run 2–3 real commands from this lesson in your lab and note outputs
- **C:** rewrite answers from memory next day

Do not open `solutions/40-security-groups/` until after an honest attempt.

Self-check

1. Timeout often means?
2. RST often means?
3. Why defense in depth?

Further reading

- https://docs.aws.amazon.com/vpc/latest/userguide/vpc-security-groups.html